

Documento de Regras de Negócio para Desenvolvimento -

Lei Geral de Proteção de Dados (LGPD)

	Papel	Descrição
Titular dos Dados		Pessoa natural a quem os dados pessoais se referem. Ex.: candidato a uma vaga de emprego, cliente ou colaborador.
Controlador		Pessoa física ou jurídica responsável por decidir a finalidade e a forma como os dados pessoais serão tratados. É quem define "o que será feito" com os dados.
Operador		Pessoa física ou jurídica que realiza o tratamento dos dados pessoais em nome do controlador, seguindo suas instruções. Não decide a finalidade do tratamento.
Encarregado (DPO – Data Protection Officer)		Pessoa indicada pelo controlador para atuar como canal de comunicação entre o controlador, os titulares dos dados e a ANPD. Também orienta sobre boas práticas relacionadas à proteção de dados.
ANPD (Autoridade Nacional de Proteção de Dados)		Órgão responsável por fiscalizar o cumprimento da LGPD, editar normas complementares, orientar agentes de tratamento e aplicar sanções quando houver descumprimento da lei.
Agentes de Tratamento		Termo utilizado pela LGPD para se referir, em conjunto, ao Controlador e ao Operador , pois ambos participam do tratamento de dados pessoais e possuem responsabilidades previstas na lei.

RN001 – Registro das operações de tratamento

Base legal: Art. 37

Objetivo: Garantir que exista rastreabilidade das atividades realizadas com dados pessoais.

A plataforma deverá permitir

- ☐ **Registrar operações de tratamento** – guardar informações sobre ações realizadas com dados pessoais, como coleta, consulta, alteração, compartilhamento e exclusão.
- ☐ **Manter histórico das operações** – preservar os registros para comprovação das atividades realizadas.
- ☐ **Identificar tratamentos baseados em legítimo interesse** – indicar quando a base legal utilizada for o legítimo interesse do controlador.

RN002 – Tratamento conforme instruções do controlador

Base legal: Art. 39

Objetivo: Garantir que o operador execute o tratamento de acordo com as definições do controlador.

A plataforma deverá permitir

- ☐ **Executar tratamentos conforme regras definidas** – processar os dados apenas de acordo com as instruções estabelecidas pelo controlador.

RN003 – Cadastro do encarregado

Base legal: Art. 41

Objetivo: Disponibilizar o responsável pelo canal de comunicação sobre proteção de dados.

A plataforma deverá permitir

- ☐ **Cadastrar o encarregado** – registrar a pessoa responsável pelo tratamento de dados.
- ☐ **Exibir a identificação do encarregado** – mostrar nome ou identificação do responsável.
- ☐ **Exibir informações de contato** – disponibilizar meios de contato para titulares e ANPD.

RN004 – Proteção contra acesso não autorizado

Base legal: Art. 46

Objetivo: Proteger os dados pessoais contra uso indevido e incidentes de segurança.

A plataforma deverá possuir mecanismos para proteger os dados contra

- ☐ **Acesso não autorizado** – impedir que pessoas sem permissão acessem os dados.
- ☐ **Destruição acidental** – evitar perda causada por falha ou erro não intencional.
- ☐ **Destruição ilícita** – impedir exclusão deliberada indevida dos dados.
- ☐ **Perda de dados** – reduzir risco de indisponibilidade ou desaparecimento das informações.
- ☐ **Alteração indevida** – impedir modificações sem autorização.
- ☐ **Comunicação indevida** – evitar envio ou divulgação para destinatários não autorizados.
- ☐ **Tratamento inadequado** – impedir uso incompatível com a finalidade informada.
- ☐ **Tratamento ilícito** – impedir operações em desacordo com a LGPD.

RN005 – Segurança desde a concepção

Base legal: Art. 46 §2º

Objetivo: Considerar proteção de dados desde o início do desenvolvimento do produto.

A plataforma deverá

- ☐ **Aplicar segurança na concepção** – considerar requisitos de proteção de dados durante o planejamento e desenvolvimento.
- ☐ **Manter segurança durante a execução** – garantir que as medidas continuem válidas enquanto o sistema estiver em operação.

RN006 – Segurança após o encerramento do tratamento

Base legal: Art. 47

Objetivo: Garantir que a obrigação de sigilo permaneça mesmo após o término do tratamento.

A plataforma deverá garantir proteção dos dados

- ☐ **Durante o tratamento** – enquanto os dados estiverem sendo utilizados.
- ☐ **Após o encerramento** – mesmo depois do término da atividade de tratamento
- ☐ **Pedido de exclusão de dados** - excluir os dados mantendo histórico do registro em tabela de log com o devido hash gerado.

RN007 – Comunicação de incidente

Base legal: Art. 48

Objetivo: Permitir registro e controle de incidentes de segurança envolvendo dados pessoais.

A plataforma deverá permitir

- ☐ **Registrar incidente de segurança** – cadastrar ocorrências que envolvam risco aos dados pessoais.
- ☐ **Registrar comunicação à ANPD** – armazenar a informação de que a autoridade foi comunicada.
- ☐ **Registrar comunicação ao titular** – armazenar a informação de que os titulares foram comunicados.

RN008 – Informações do incidente

Base legal: Art. 48 §1º

Objetivo: Garantir que o incidente contenha as informações mínimas exigidas pela LGPD.

A plataforma deverá permitir registrar

- ☐ **Natureza dos dados afetados** – quais tipos de dados foram impactados.
- ☐ **Titulares envolvidos** – quais pessoas podem ter sido afetadas.
- ☐ **Medidas de segurança utilizadas** – quais proteções estavam aplicadas aos dados.
- ☐ **Riscos do incidente** – quais impactos podem ocorrer para os titulares.
- ☐ **Motivo da demora na comunicação** – justificativa caso a comunicação não tenha sido imediata.
- ☐ **Medidas de mitigação** – ações adotadas ou planejadas para reduzir os efeitos do incidente.

RN009 – Estrutura do sistema

Base legal: Art. 49

Objetivo: Garantir que o sistema seja construído em conformidade com os princípios da LGPD.

A plataforma deverá atender

- ☐ **Requisitos de segurança** – proteção adequada das informações tratadas.
- ☐ **Boas práticas** – observância de práticas reconhecidas de proteção de dados.
- ☐ **Governança** – existência de regras e responsabilidades relacionadas ao tratamento.
- ☐ **Princípios da LGPD** – respeito à finalidade, necessidade, transparência e demais princípios legais.
- ☐ **Normas regulamentares** – o sistema deverá permitir adequação às normas complementares emitidas pela ANPD aplicáveis ao tratamento de dados pessoais. (Essas normas complementares podem surgir como incremental com o passar do tempo).

RN010 – Publicação das informações do encarregado

Base legal: Art. 41 §1º

Objetivo: Garantir acesso público ao canal responsável por proteção de dados.

A plataforma deverá permitir

- ☐ **Publicar a identidade do encarregado** – tornar público quem é o responsável.
- ☐ **Publicar informações de contato** – disponibilizar canais para solicitações e reclamações.
- ☐ **Exibir de forma clara e objetiva** – apresentar as informações de maneira facilmente compreensível.

Itens “adicionais” para o MVP

RN011 – Direitos do titular dos dados

Base legal: Arts. 18 e 19

Objetivo: Garantir que o titular possa exercer os direitos previstos na LGPD por meio do sistema ou de canal formal de atendimento.

A plataforma deverá permitir

- ☐ **Confirmar a existência de tratamento** – informar ao titular se seus dados pessoais são objeto de tratamento.
- ☐ **Disponibilizar acesso aos dados pessoais** – permitir que o titular consulte os dados pessoais tratados a seu respeito.
- ☐ **Corrigir dados incompletos, inexatos ou desatualizados** – permitir a solicitação ou realização da correção dos dados.
- ☐ **Anonimizar, bloquear ou eliminar dados desnecessários, excessivos ou tratados em desconformidade com a LGPD** – atender às solicitações quando aplicáveis.
- ☐ **Realizar a portabilidade dos dados** – permitir a disponibilização dos dados a outro fornecedor de serviço ou produto, mediante requisição expressa do titular, observados os segredos comercial e industrial e a regulamentação da ANPD.
- ☐ **Eliminar dados tratados com base no consentimento** – excluir os dados quando houver revogação do consentimento, ressalvadas as hipóteses legais de conservação previstas na LGPD.
- ☐ **Informar as entidades públicas e privadas com as quais os dados foram compartilhados** – disponibilizar ao titular a relação de terceiros com quem seus dados foram compartilhados.

- ☐ **Informar sobre a possibilidade de não fornecer consentimento** – apresentar as consequências da negativa quando o tratamento depender do consentimento.
 - ☐ **Permitir a revogação do consentimento** – possibilitar que o titular revogue o consentimento por procedimento facilitado e gratuito.
 - ☐ **Disponibilizar confirmação simplificada da existência de tratamento**, quando aplicável.
 - ☐ **Disponibilizar declaração completa das informações solicitadas pelo titular**, observando o prazo previsto na LGPD.
-

RN012 – Base legal do tratamento de dados

Base legal: Arts. 7º, 10 e 11

Objetivo: Garantir que todo tratamento de dados pessoais realizado pela plataforma esteja associado a uma base legal prevista na LGPD.

A plataforma deverá permitir

- ☐ **Vincular cada finalidade de tratamento a uma base legal** – associar cada operação de tratamento a uma das hipóteses previstas na LGPD.
 - ☐ **Registrar a base legal utilizada** – manter registrada a base legal aplicada em cada tratamento de dados.
 - ☐ **Diferenciar o tratamento de dados pessoais comuns e dados pessoais sensíveis** – aplicar as hipóteses legais correspondentes a cada categoria de dado.
 - ☐ **Documentar o tratamento baseado em legítimo interesse** – registrar a finalidade do tratamento e os dados estritamente necessários quando essa base legal for utilizada.
-

RN013 – Gestão de consentimento

Base legal: Art. 8º

Objetivo: Garantir que o consentimento seja obtido, registrado e gerenciado conforme os requisitos da LGPD.

A plataforma deverá permitir

- ☐ **Coletar o consentimento de forma destacada** – apresentar a solicitação de consentimento separadamente das demais cláusulas, indicando finalidade determinada.
- ☐ **Registrar a comprovação do consentimento** – manter registro do consentimento concedido pelo titular.

- ☐ **Permitir a revogação do consentimento** – possibilitar ao titular revogar o consentimento por procedimento facilitado e gratuito.
 - ☐ **Considerar inválido o consentimento obtido de forma inadequada** – impedir a utilização de consentimento obtido mediante erro, informação enganosa, abusiva ou vício de consentimento.
 - ☐ **Solicitar novo consentimento quando houver alteração da finalidade do tratamento**, quando essa alteração exigir nova manifestação do titular.
-

RN014 – Tratamento de dados pessoais sensíveis

Base legal: Arts. 5º, II e 11

Objetivo: Garantir que os dados pessoais sensíveis sejam tratados de acordo com as hipóteses específicas previstas na LGPD.

A plataforma deverá permitir

- ☐ **Identificar os dados pessoais sensíveis** – classificar os dados enquadrados na definição do art. 5º, inciso II.
 - ☐ **Aplicar apenas as bases legais previstas para dados sensíveis** – restringir o tratamento às hipóteses autorizadas pelo art. 11.
 - ☐ **Restringir o acesso aos dados sensíveis aos usuários autorizados**, conforme as regras definidas pelo controlador.
 - ☐ **Registrar a finalidade do tratamento dos dados sensíveis** – documentar a finalidade para a qual o dado sensível está sendo tratado.
-

RN015 – Relatório de Impacto à Proteção de Dados Pessoais (RIPD)

Base legal: Art. 38

Objetivo: Permitir o registro e a gestão do Relatório de Impacto à Proteção de Dados Pessoais quando exigido pela ANPD ou adotado pelo controlador.

A plataforma deverá permitir

- ☐ **Registrar a existência de Relatório de Impacto**, quando elaborado.
 - ☐ **Relacionar o relatório às operações de tratamento correspondentes.**
 - ☐ **Disponibilizar o relatório para atendimento de eventual solicitação da ANPD.**
-

RN016 – Retenção e eliminação de dados pessoais

Base legal: Arts. 15 e 16

Objetivo: Garantir que os dados pessoais sejam mantidos apenas pelo período permitido pela LGPD.

A plataforma deverá permitir

- ☐ **Definir prazos de retenção conforme a finalidade e a base legal do tratamento.**
 - ☐ **Eliminar ou anonimizar os dados pessoais quando encerrada a finalidade do tratamento**, observadas as hipóteses legais de conservação.
 - ☐ **Permitir a manutenção dos dados apenas nas hipóteses previstas no art. 16**, como cumprimento de obrigação legal, estudo por órgão de pesquisa, transferência a terceiro ou uso exclusivo do controlador com anonimização sempre que possível.
 - ☐ **Registrar o histórico das eliminações realizadas**, permitindo comprovação das operações efetuadas.
-

RN017 – Gestão de operadores de tratamento

Base legal: Art. 39

Objetivo: Garantir o controle dos operadores que realizam tratamento de dados pessoais em nome do controlador.

A plataforma deverá permitir

- ☐ **Cadastrar os operadores responsáveis pelo tratamento de dados pessoais.**
 - ☐ **Registrar a finalidade do compartilhamento de dados com cada operador.**
 - ☐ **Associar ao operador a existência de instrumento contratual aplicável**, quando utilizado pelo controlador.
 - ☐ **Registrar as verificações realizadas pelo controlador quanto ao cumprimento das instruções fornecidas ao operador.**
-

Para um sistema aderente à LGPD

Uma abordagem bastante utilizada é armazenar:

Campo	Finalidade
CPF criptografado (AES-256)	Permitir recuperação quando necessária
Hash HMAC-SHA-256 do CPF	Pesquisa, deduplicação e identificação sem expor o dado
CPF mascarado	Exibição na interface para usuários autorizados

Assim, o sistema consegue buscar registros pelo CPF de forma eficiente, recuperar o valor quando houver necessidade legítima e exibir apenas uma versão mascarada na interface, reduzindo a exposição do dado pessoal.

Recomendado

Para uma plataforma de vagas como o <Cad!date!>, a sugestão é:

- **Hash: HMAC-SHA-256** para identificação e buscas por CPF.
- **Armazenamento: AES-256** para os casos em que o CPF precise ser recuperado.
- **Exibição:** máscara visual (*****.***.123-45**) para minimizar a exposição do dado.